Software Requirements Specification (SRS) - Bank Management System

Version: 1.0 (Draft)

Status: Draft

Owner: Tarini Arora

Team: BMS_PES

Date: 12-10-2026

This document specifies the intended requirements for the Bank Management System.

Document Control

Version	Date	Owner	Change summary	Approval
1.0	12-10-2026	BMS_PES	Requirements, quality, security, business rules and traceability for the Bank Management System.	Draft

Approvals

Role	Name	Signature
Project reviewer		

Contents

Document Control 2
Approvals 2
1. Introduction 3
1.1 Purpose 3
1.2 Scope 4
1.3 Document conventions and terminology 4
1.4 References 4
2. Overall Description 4
2.1 Product perspective 4
2.2 Product functions 4
2.3 User classes 5
2.4 Operating environment 5
2.5 Constraints 5
2.6 Business rules 5
2.7 Assumptions and dependencies 5
3. External Interface Requirements 6
3.1 User interface 6
3.2 Software interface 6
3.3 Communication interface 6
3.4 Hardware interfaces 6
4. System Features 6
4.1 Authentication and access control 6
BMS-F-001 - Authenticate user and create session 6
BMS-F-002 - Lock user after three failed logins 6
BMS-F-003 - Enforce role-based access 7
BMS-F-004 - Change password and force first-login change 7
4.2 Account management 7
BMS-F-010 - Open account and create first Customer login 7
BMS-F-011 - Update customer contact details 8
BMS-F-012 - Freeze, unfreeze or close account 8
BMS-F-013 - Customer views own accounts and balance 8

BMS-F-014 - Search customers....8
4.3 Transactions (deposit, withdrawal, transfer, history and statements)....9
BMS-F-020 - Record cash deposit....9
BMS-F-021 - Record withdrawal within balance and daily limit....9
BMS-F-022 - Transfer funds between BMS accounts....9
BMS-F-023 - View transaction history and mini-statement....9
BMS-F-024 - Download account statement....9
4.4 Admin, audit, reporting and notification....10
BMS-F-030 - Manage Teller user accounts....10
BMS-F-031 - View filtered audit log....10
BMS-F-032 - Generate daily transaction summary....10
BMS-F-033 - Log simulated transaction notification....10
5. Non-functional requirements (detailed)....10
BMS-NF-001 - Transaction response time....11
BMS-NF-002 - Availability and health endpoint....11
BMS-NF-003 - Atomic financial transactions....11
BMS-NF-004 - First-time-user transfer usability....11
BMS-NF-005 - Audit log integrity and retention....11
BMS-NF-006 - Browser compatibility and responsive UI....12
5.1 Security....12
5.1.1 Security objectives....12
5.1.2 Security requirements....12
BMS-SR-001 - Require TLS for client-server communication....12
BMS-SR-002 - Protect stored passwords....12
BMS-SR-003 - Expire idle sessions....12
BMS-SR-004 - Enforce server-side authorization....13
BMS-SR-005 - Validate input and mitigate SQL injection and XSS....13
BMS-SR-006 - Audit security-relevant actions....13
BMS-SR-007 - Mask account numbers and protect ID-proof numbers....13
6. Quality attributes and acceptance tests....14
6.1 Quality attribute targets....14
6.2 Exit criteria....14
6.3 Acceptance test suites....14
7. System Models and Diagrams....15
7.1 UML use-case diagram 1 - Customer and Teller....15
7.2 UML use-case diagram 2 - Admin and system....16
8. Requirements Traceability Matrix (RTM)....16

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional, non-functional, security, interface and traceability requirements for the Bank Management System (BMS) software engineering mini-project. It provides a common baseline for

design, implementation, testing and review. Requirements in this draft describe intended behaviour; they do not assert that a feature has been implemented or verified.

1.2 Scope

The BMS is a web-based system for a single bank. It supports three user roles - Customer, Teller and Admin - and is intended to cover account opening and account information, cash deposits and withdrawals, internal BMS fund transfers, transaction history and downloadable statements, administrative Teller management, audit-log review, daily transaction reporting, and simulated debit/credit notifications.

Out of scope: loans, cards, cheques, NEFT/UPI/RTGS, mobile app, real SMS/e-mail gateway, and customer self-registration. Notifications are simulated and logged. Transfers are between accounts within the BMS.

1.3 Document conventions and terminology

- “Shall” identifies a mandatory requirement. Each requirement has a fixed identifier; requirement IDs from the documented requirements are preserved.

- BMS - Bank Management System; SRS - Software Requirements Specification; RTM - Requirements Traceability Matrix; NFR - non-functional requirement.

- Customer - user who can view their own accounts, transfer funds, and view/download transaction history and statements.

- Teller - bank staff user who opens accounts, updates customer contact details, searches customers, and records cash deposits/withdrawals.

- Admin - staff role that manages Teller user accounts, changes account status, reviews audit logs and generates daily reports.

- ACID - atomicity, consistency, isolation and durability. REST/JSON - the stated web API interface style.

- Acceptance criteria and test identifiers describe planned verification. RTM status “N” means not started; it does not mean a test passed.

1.4 References

- Repository README: SE_Jackfruit - Bank Management System (project scope, technology baseline and repository structure).

- Software Architecture Document (SAD), version 1.0.

- Test Plan, version 1.0.

- Software Requirements Specification template.

2. Overall Description

2.1 Product perspective

The BMS is described as a layered web application. The project technology baseline in the repository README is Python 3 with FastAPI for REST/JSON, SQLite accessed through SQLAlchemy, an HTML/CSS/JavaScript web interface, pytest for automated testing, and GitHub Actions for CI. This SRS does not introduce a different stack.

2.2 Product functions

- Authenticate users, establish sessions, lock accounts after repeated failed login attempts, enforce roles and support password change / first-login password change.

- Open Savings and Current accounts, maintain customer contact details, search customers, show a Customer their own account details and balance, and let Admins freeze, unfreeze or close accounts.

- Record deposits and withdrawals, transfer funds between eligible BMS accounts, show filtered transaction history and mini-statements, and provide CSV/PDF statement downloads.

- Allow Admins to create, deactivate and unlock Teller users, review filtered audit logs, and generate daily transaction summaries.

- Record simulated e-mail/SMS notification entries after debit or credit events, without a real external gateway.

- Apply performance, availability, integrity, usability, compatibility, audit-retention and security requirements stated in Sections 5 and 6.

2.3 User classes

User class	Main responsibilities / permitted functions
Customer	View only their own account details and balance; transfer funds from their account to another eligible BMS account; view transaction history and download statements; receive a simulated notification record after debit/credit activity.
Teller	Open Savings/Current accounts; update customer phone, e-mail and address; search customers; record eligible deposits and withdrawals.
Admin	Create, deactivate and unlock Teller user accounts; freeze, unfreeze or close accounts subject to the balance rule; review filtered audit logs; generate daily transaction summaries.

The system must enforce these permissions on the server, not only through UI controls. The permission matrix shall be consistent across this SRS, the SAD and the Test Plan.

2.4 Operating environment

- Backend/API: Python 3 and FastAPI, with REST/JSON interfaces.

- Database: SQLite through SQLAlchemy.

- Client: HTML, CSS and JavaScript in a browser; compatibility target is the latest two versions of Chrome, Edge and Firefox, including a 360 px viewport.

- Verification/automation: pytest and GitHub Actions per the repository baseline; load/performance and usability tools must be identified in the test plan where applicable.

2.5 Constraints

- The project is for one bank and excludes loans, cards, cheques, NEFT/UPI/RTGS, a mobile app, real SMS/e-mail gateway delivery, and customer self-registration.

- Notifications are simulated and stored in the notification log; real SMS/e-mail gateway delivery is outside the project scope.

- Business rules BR-01 to BR-08 are specified in Section 2.6.

2.6 Business rules

Rule ID	Business rule
BR-01	Savings accounts must maintain a minimum balance of ₹1,000. Current accounts must maintain a minimum balance of ₹5,000. Account opening

Rule ID	Business rule
	deposits must meet the applicable minimum balance.
BR-02	The maximum withdrawal is ₹50,000 per account per day.
BR-03	The maximum amount per fund transfer is ₹1,00,000. The maximum amount per cash deposit is ₹2,00,000.
BR-04	Frozen or closed accounts cannot perform transactions. An account may be closed only when its balance is exactly ₹0.
BR-05	Accounts must not be overdrawn. Withdrawals and other debits must comply with applicable balance and minimum-balance rules.
BR-06	Every account number must be unique and contain exactly 10 digits.
BR-07	Three consecutive failed login attempts lock the user account. Only an Admin may unlock a locked account.
BR-08	Customers cannot self-register. When a Teller opens a customer's first account, the system creates a customer login only if one does not already exist. The username must match the customer ID. The temporary password is shown to the Teller only once, is never logged or stored in recoverable form, and must be changed by the Customer at first login.

2.7 Assumptions and dependencies

- Teller and Admin actions are performed by authenticated users assigned the appropriate role.

- The ledger/transaction records are the source used to reconcile displayed balances and daily summaries.

- A customer may hold more than one account (BR-08).

- The business rules in Section 2.6 govern account opening, account status, withdrawals, transfers, deposits, account identifiers and login security.

- The Test Plan and SAD are maintained separately under docs/test-plan/ and docs/sad/; use the same requirement and design-spec IDs.

3. External Interface Requirements

3.1 User interface

The system shall expose the supported functions through a simple browser-based HTML/CSS/JavaScript interface. The available functions shall depend on the authenticated role. The UI shall present clear rejection messages for invalid transactions and account-status restrictions, support the transaction-history and statement flows, and satisfy BMS-NF-006 browser and responsive-viewport targets.

3.2 Software interface

- The browser client communicates with the FastAPI backend through REST/JSON interfaces in accordance with the repository baseline.

- The backend accesses SQLite through SQLAlchemy. Database operations affecting a transfer must satisfy BMS-NF-003 atomicity.

- The system is intended to use pytest and GitHub Actions for automated verification/CI. Exact service/module contracts are controlled by the SAD.

3.3 Communication interface

Client-server communication shall use TLS 1.2 or higher as required by BMS-SR-001. Deployment endpoints, certificates and local-development settings shall be documented in the SAD and test environment documentation without weakening this requirement.

3.4 Hardware interfaces

The system has no dedicated hardware interface. Users access the BMS through a standard computer or mobile-device browser, keyboard, pointing device and display. No dedicated banking-terminal, card-reader, cheque-processing or external payment-terminal hardware is part of the system.

4. System Features

4.1 Authentication and access control

BMS-F-001 - Authenticate user and create session

Type / category: Functional

Source / stakeholder: Customer / Teller / Admin

Requirement statement: The system shall authenticate a user using a unique username and password and establish an authenticated session within 3 seconds of valid credential submission.

Priority: High

Acceptance criteria / test reference: Valid credentials establish a session within 3 seconds and return the user's role; invalid credentials are rejected without revealing which credential was incorrect. Test: TC-Auth-01.

Dependencies / comments: DS-AUTH.

BMS-F-002 - Lock user after three failed logins

Type / category: Functional

Source / stakeholder: Customer / Teller / Admin

Requirement statement: The system shall lock a user account after three consecutive failed login attempts, record an audit event for the lockout, and permit only an Admin to unlock the account, in accordance with BR-07.

Priority: High

Acceptance criteria / test reference: The third consecutive failed attempt locks the account and creates an audit event; subsequent login attempts are rejected until an Admin unlocks the account. Test: TC-Auth-02.

Dependencies / comments: DS-AUTH, DS-AUD.

BMS-F-003 - Enforce role-based access

Requirement statement: The system shall enforce role-based access to system functions for Customer, Teller and Admin users on the server.

Type / category: Functional

Priority: High

Source / stakeholder: Customer, Teller, Admin

Acceptance criteria / test reference: A request by a role that is not permitted to perform the action is denied by the server; UI hiding alone is not sufficient. Test: TC-RBAC-01.

Dependencies / comments: DS-AUTH; related security requirement BMS-SR-004.

BMS-F-004 - Change password and force first-login change

Type / category: Functional

Source / stakeholder: Customer / Teller / Admin

Requirement statement: The system shall allow an authenticated user to change their password after entering their current password. A new password shall contain at least 8 characters, including at least one uppercase letter, one lowercase letter and one digit. Customers receiving a temporary password during account opening shall be required to change it at first login.

Priority: Medium

Acceptance criteria / test reference: A correct current password and a compliant new password update the password; an incorrect current password or a password that fails the stated policy is rejected. Customers with temporary credentials must change the password before using other functions. Test: TC-Auth-03.

Dependencies / comments: DS-AUTH; BMS-F-010 creates the temporary Customer credential.

4.2 Account management

This feature group enables authorized Tellers to open accounts, update customer contact details and search customers; Admins can freeze, unfreeze or close accounts; Customers can view only their own account details and current balance.

BMS-F-010 - Open account and create first Customer login

Requirement statement: The system shall allow an authorized Teller to open a Savings or Current account by capturing the customer name, date of birth, address, phone number, e-mail address and ID-proof number, and by recording an opening deposit that meets the minimum balance for the selected account type under BR-01. Each account shall receive a unique 10-digit account number and start with Active status. The opening deposit shall be recorded as a transaction. A Customer login shall be created only if the customer does not already have one; customer self-registration shall not be permitted. The login username shall match the customer ID. The system shall generate a temporary password, display it to the Teller once, and neither log it nor store it in recoverable form.

Type / category: Functional

Priority: High

Source / stakeholder: Bank Operations

Acceptance criteria / test reference: A unique 10-digit account number is generated; account status is Active; the opening deposit meets BR-01 and is recorded as a transaction; the username equals the customer ID; a temporary password is displayed to the Teller only once and is absent from logs and recoverable storage; a Customer login is created only when one does not already exist; no duplicate login is created for an existing customer; the Customer is required to change the temporary password at first login before accessing other functions. E-mail address is captured as part of account opening. Test: TC-Acc-01.

Dependencies / comments: BR-01, BR-06, BR-08; DS-ACC, DS-AUTH, DS-TXN, DS-DB. The customer must change the temporary password at first login under BMS-F-004. E-mail is captured during onboarding and can later be updated under BMS-F-011.

BMS-F-011 - Update customer contact details

Requirement statement: The system shall allow a Teller to update a customer's phone, e-mail and address and record the old and new values.

Type / category: Functional

Priority: Medium

Source / stakeholder: Bank Operations

Acceptance criteria / test reference: Updated values are visible immediately; an audit entry holds the old and new values. Test: TC-Acc-02.

Dependencies / comments: Audit recording; DS-ACC and DS-AUD.

BMS-F-012 - Freeze, unfreeze or close account

Requirement statement: The system shall allow an Admin to freeze, unfreeze or close an account. Frozen or closed accounts shall not be permitted to perform transactions. Account closure shall be rejected unless the account balance is exactly ₹0. Each account lifecycle action shall be recorded in the audit log.

Type / category: Functional

Priority: High

Source / stakeholder: Bank Operations / Compliance

Acceptance criteria / test reference: Frozen or closed accounts reject transactions; an account with a non-zero balance cannot be closed; freeze, unfreeze and close actions are audit-logged. Test: TC-Acc-03.

Dependencies / comments: BR-04; DS-ACC, DS-TXN and DS-AUD. Authorization must be enforced server-side; lifecycle actions must be audit-logged.

BMS-F-013 - Customer views own accounts and balance

Requirement statement: The system shall allow an authenticated Customer to view details and current balance of only their own accounts. The server shall reject attempts to access another customer’s account with HTTP 403; access control shall not rely solely on UI hiding.

Type / category: Functional

Priority: High

Source / stakeholder: Customer

Acceptance criteria / test reference: Displayed balance equals the ledger sum; attempting to access another customer's account returns HTTP 403. Test: TC-Acc-04.

Dependencies / comments: Server-side authorization under BMS-F-003 / BMS-SR-004; DS-ACC, DS-AUTH and DS-DB.

BMS-F-014 - Search customers

Requirement statement: The system shall allow a Teller to search customers by name, account number or phone and return matching results within 2 seconds.

Type / category: Functional

Priority: Medium

Source / stakeholder: Bank Operations

Acceptance criteria / test reference: Full- and partial-name searches and searches by account number or phone number return matching customers within 2 seconds; no match displays “No results”; account numbers shown in results follow BMS-SR-007 masking (only the last four digits are visible). Test: TC-Acc-05.

Dependencies / comments: DS-ACC and DS-DB; displayed account numbers must follow BMS-SR-007 masking rules where applicable.

4.3 Transactions (deposit, withdrawal, transfer, history and statements)

The system shall record cash deposits and withdrawals, transfer funds between eligible BMS accounts, and provide transaction history and downloadable statements. All money movement is subject to the business rules in Section 2.6.

BMS-F-020 - Record cash deposit

Requirement statement: The system shall allow a Teller to record a cash deposit greater than ₹0 and less than or equal to ₹2,00,000 to an Active account and generate a receipt number.

Type / category: Functional

Priority: High

Source / stakeholder: Bank Operations / Customer

Acceptance criteria / test reference: The balance increases by the exact deposited amount and a transaction record is created. Test: TC-Dep-01.

Dependencies / comments: BMS-F-010; business rules BR-03 and BR-04.

BMS-F-021 - Record withdrawal within balance and daily limit

Requirement statement: The system shall allow a Teller to record a withdrawal only if the post-withdrawal balance is greater than or equal to the minimum balance and the daily limit (BR-02) is not exceeded.

Type / category: Functional

Priority: High

Source / stakeholder: Bank Operations / Customer

Acceptance criteria / test reference: A valid withdrawal reduces the balance; an invalid withdrawal is rejected with a reason. Tests: TC-WD-01 and TC-WD-02.

Dependencies / comments: Business rules BR-01, BR-02 and BR-05.

BMS-F-022 - Transfer funds between BMS accounts

Requirement statement: The system shall allow a Customer to transfer up to ₹1,00,000 per transfer from their account to another Active BMS account, rejecting transfers with insufficient funds or frozen/closed accounts.

Type / category: Functional

Priority: High

Source / stakeholder: Customer / Business

Acceptance criteria / test reference: The debit and credit both succeed or both fail; two transaction records are created. Tests: TC-TR-01 and TC-TR-02.

Dependencies / comments: Business rules BR-03, BR-04 and BR-05; related to BMS-NF-003.

BMS-F-023 - View transaction history and mini-statement

Requirement statement: The system shall allow a Customer to view their account transaction history filtered by date range, with the latest 10 transactions shown as a mini-statement.

Type / category: Functional

Priority: Medium

Source / stakeholder: Customer

Acceptance criteria / test reference: Only transactions within the selected range are shown, newest first. Test: TC-Stmt-01.

Dependencies / comments: Depends on BMS-F-020, BMS-F-021 and BMS-F-022.

BMS-F-024 - Download account statement

Requirement statement: The system shall allow a Customer to download a statement in CSV or PDF format for a chosen date range.

Type / category: Functional

Priority: Low

Source / stakeholder: Customer / Compliance

Acceptance criteria / test reference: Totals in the downloaded file match the on-screen history. Test: TC-Stmt-02.

Dependencies / comments: Depends on BMS-F-023.

4.4 Admin, audit, reporting and notification

This feature group provides authorized administration of Teller accounts, account-status changes, audit-log review, daily transaction reporting and simulated notification logging. Staff-management and account-status operations are restricted to Admin users. Notifications are written to a local log and are not sent through a real external SMS/e-mail gateway.

BMS-F-030 - Manage Teller user accounts

Requirement statement: The system shall allow an Admin to create, deactivate and unlock Teller user accounts.

Type / category: Functional

Priority: High

Source / stakeholder: Bank Operations

Acceptance criteria / test reference: A new Teller can log in; a deactivated Teller cannot log in; an unlocked Teller can log in again. Test: TC-Adm-01.

Dependencies / comments: DS-ADM and DS-AUTH.

BMS-F-031 - View filtered audit log

Requirement statement: The system shall allow an Admin to view the audit log filtered by user, action type and date.

Type / category: Functional

Priority: Medium

Source / stakeholder: Bank Operations / Compliance

Acceptance criteria / test reference: The filter returns only matching entries. Test: TC-Aud-01.

Dependencies / comments: Audit entries are produced under BMS-SR-006.

BMS-F-032 - Generate daily transaction summary

Requirement statement: The system shall generate a daily transaction summary for Admin showing the count and total of deposits, withdrawals and transfers.

Type / category: Functional

Priority: Medium

Source / stakeholder: Bank Operations

Acceptance criteria / test reference: Report totals match the transaction table for the selected day. Test: TC-Rep-01.

Dependencies / comments: Uses transaction records for the selected day.

BMS-F-033 - Log simulated transaction notification

Requirement statement: The system shall create a simulated e-mail/SMS notification record for the Customer after every debit or credit.

Type / category: Functional

Priority: Low

Source / stakeholder: Customer / Bank Operations

Acceptance criteria / test reference: One notification record is created per credited or debited account. Test: TC-Not-01.

Dependencies / comments: No real SMS/e-mail gateway is in scope; the Customer is the recipient.

5. Non-functional requirements (detailed)

The quality requirements below are targets to be verified. Their inclusion is not a claim that the targets have already been achieved.

BMS-NF-001 - Transaction response time

Requirement statement: At least 95% of deposit, withdrawal and transfer requests shall complete within 3 seconds with 50 concurrent users.

Type / category: Performance

Priority: High

Source / stakeholder: Bank Operations / Customer

Acceptance criteria / test reference: A load-test run with 50 concurrent users demonstrates a 95th-percentile response time no greater than 3 seconds. Test: TC-Perf-01.

Dependencies / comments: DS-TXN; load-test tool/configuration to be specified in the Test Plan.

BMS-NF-002 - Availability and health endpoint

Requirement statement: The system shall be available 99.5% of each month, excluding scheduled maintenance, and expose a /health endpoint.

Type / category: Reliability

Priority: Medium

Source / stakeholder: Bank Operations

Acceptance criteria / test reference: /health returns HTTP 200 within 1 second; availability is verified from an uptime log. Test: TC-Ops-01.

Dependencies / comments: DS-UI / platform; the measurement window and uptime source should be confirmed in the Test Plan.

BMS-NF-003 - Atomic financial transactions

Requirement statement: Every financial transaction shall be atomic (ACID): a failed transfer leaves both account balances unchanged.

Type / category: Data integrity

Priority: High

Source / stakeholder: Customer / Bank Operations

Acceptance criteria / test reference: A fault-injection test shows no partial transfer update: either both sides commit or neither does. Test: TC-TR-02.

Dependencies / comments: DS-TXN, DS-DB.

BMS-NF-004 - First-time-user transfer usability

Requirement statement: At least 9 of 10 first-time users shall complete a fund transfer within 2 minutes without assistance.

Type / category: Usability

Priority: Medium

Source / stakeholder: Customer

Acceptance criteria / test reference: At least 9 of 10 first-time users complete a fund transfer within 2 minutes without assistance. Test: TC-UX-01.

Dependencies / comments: DS-UI.

BMS-NF-005 - Audit log integrity and retention

Requirement statement: Audit logs shall be timestamped, append-only and retained for at least 5 years.

Type / category: Audit / retention

Priority: Medium

Source / stakeholder: Bank Operations / Compliance

Acceptance criteria / test reference: There is no ordinary application update/delete path for audit logs; retention configuration is verified. Test: TC-Aud-02.

Dependencies / comments: DS-AUD.

BMS-NF-006 - Browser compatibility and responsive UI

Requirement statement: The UI shall work on the latest two versions of Chrome, Edge and Firefox and be usable at a viewport width of 360 px.

Type / category: Compatibility

Priority: Medium

Source / stakeholder: Customer / Teller / Admin

Acceptance criteria / test reference: Manual checks pass on the specified browser versions and a 360 px responsive viewport. Test: TC-UX-02.

Dependencies / comments: DS-UI. The exact browser versions should be recorded when tests are performed.

5.1 Security

5.1.1 Security objectives

Objective ID	Objective	Description
BMS-SO-1	Confidentiality	Customer and credential data shall be visible only to authorized users. Sensitive identifiers and authentication secrets shall be protected against unauthorized disclosure.
BMS-SO-2	Integrity	Money movements and account data shall not be altered illegitimately or left in an inconsistent state. Validation, role enforcement and atomic transaction handling shall support this objective.
BMS-SO-3	Accountability	Every security-relevant action shall be traceable to a user through timestamped audit records that identify the action and outcome.

5.1.2 Security requirements

BMS-SR-001 - Require TLS for client-server communication

Requirement statement: The system shall use TLS 1.2 or higher for all client-server communication.

Type / category: Security

Priority: High

Source / stakeholder: Customer / Teller / Admin

Acceptance criteria / test reference: Verification confirms that TLS 1.2 or higher is required for client-server communication. Test: TC-Sec-01.

Security objective link: BMS-SO-1

Dependencies / comments: DS-SEC.

BMS-SR-002 - Protect stored passwords

Requirement statement: The system shall store passwords, including temporary passwords, only as salted bcrypt or Argon2 hashes and shall never write them to logs.

Type / category: Security

Priority: High

Source / stakeholder: Customer / Teller / Admin

Acceptance criteria / test reference: Stored password values are salted bcrypt/Argon2 hashes and password values are absent from logs. Test: TC-Sec-02.

Security objective link: BMS-SO-1

Dependencies / comments: DS-AUTH. A temporary password shown once to a Teller must not be written to logs or retained in recoverable form.

BMS-SR-003 - Expire idle sessions

Requirement statement: The system shall expire a session after 10 minutes of inactivity.

Type / category: Security

Priority: Medium

Source / stakeholder: Customer / Teller / Admin

Acceptance criteria / test reference: A request after 10 minutes of inactivity is rejected and requires authentication. Test: TC-Sec-03.

Security objective link: BMS-SO-1

Dependencies / comments: DS-AUTH.

BMS-SR-004 - Enforce server-side authorization

Requirement statement: The system shall enforce authorization by role on the server for every request.

Type / category: Security

Priority: High

Source / stakeholder: Customer / Teller / Admin

Acceptance criteria / test reference: A request by a role that is not eligible to perform the requested action is denied by the server. Test: TC-RBAC-01.

Security objective link: BMS-SO-1, BMS-SO-2

Dependencies / comments: DS-AUTH.

BMS-SR-005 - Validate input and mitigate SQL injection and XSS

Requirement statement: The system shall validate input on the server, use parameterized database queries to mitigate SQL injection, and apply context-appropriate output encoding to prevent cross-site scripting (XSS).

Type / category: Security

Priority: High

Source / stakeholder: Customer / Teller / Admin

Acceptance criteria / test reference: SQL-injection inputs are safely handled by parameterized queries; XSS payloads are rendered inert or rejected by appropriate output encoding and validation. Test: TC-Sec-04.

Security objective link: BMS-SO-2

Dependencies / comments: DS-SEC.

BMS-SR-006 - Audit security-relevant actions

Requirement statement: The system shall record every login, financial and administrative action in the audit log with user, timestamp, action and outcome. Audit entries shall include customer contact-detail changes (old and new values) and account lifecycle actions (freeze, unfreeze and close). Passwords and temporary passwords shall never be logged.

Type / category: Security

Priority: High

Source / stakeholder: Bank Operations / Compliance

Acceptance criteria / test reference: Required action records contain user, timestamp, action and outcome. Test: TC-Aud-01.

Security objective link: BMS-SO-3

Dependencies / comments: DS-AUD.

BMS-SR-007 - Mask account numbers and protect ID-proof numbers

Requirement statement: The system shall mask account numbers by showing only the last four digits in lists and logs, and encrypt ID-proof numbers at rest.

Type / category: Security

Priority: Medium

Source / stakeholder: Customer / Bank Operations / Compliance

Acceptance criteria / test reference: Lists and logs show only the last four account-number digits; ID-proof numbers are encrypted at rest. Test: TC-Sec-05.

Security objective link: BMS-SO-1

Dependencies / comments: Storage and encryption are defined in the SAD (DS-SEC, DS-DB).

6. Quality attributes and acceptance tests

6.1 Quality attribute targets

The quality attributes and measurable targets are specified in Section 5 under BMS-NF-001 through BMS-NF-006. These include transaction response time, availability, atomic financial transactions, usability, audit-log retention and browser compatibility.

6.2 Exit criteria

The release candidate is ready for acceptance when:

- All planned acceptance suites have been executed and results recorded.
- No unresolved Critical or High severity defects remain.
- Financial transactions satisfy the atomicity and balance business rules.
- Authentication, account lockout, role authorization and audit logging checks pass.
- Performance and availability targets have been measured against the stated workloads.
- Usability testing meets the BMS-NF-004 acceptance threshold.
- The requirements traceability matrix is updated with actual test status and evidence.

6.3 Acceptance test suites

Suite ID	Coverage	Acceptance condition
ATS-AUTH	BMS-F-001 to BMS-F-004; BMS-SR-002 to BMS-SR-004	Login, lockout, password change, session expiry and authorization tests pass.
ATS-ACC	BMS-F-010 to BMS-F-014; BR-01, BR-04, BR-06, BR-08	Account opening (including e-mail and mandatory first-login password change), contact updates with audit old/new values, Admin-only lifecycle operations and restrictions, own-account authorization, and masked customer search within 2 seconds conform to requirements.
ATS-TXN	BMS-F-020 to BMS-F-024; BR-02, BR-03, BR-05; BMS-NF-003	Deposits, withdrawals, transfers, history and statements pass with atomic balance updates and applicable limits.
ATS-ADMIN-AUD	BMS-F-030 to BMS-F-033; BMS-SR-006; BMS-NF-005	Staff management, audit review, daily reports, simulated notifications and audit retention checks pass.

Suite ID	Coverage	Acceptance condition
ATS-QUALITY	BMS-NF-001, BMS-NF-002, BMS-NF-004, BMS-NF-006; BMS-SR-001, BMS-SR-005, BMS-SR-007	Performance, health/availability, usability, compatibility, transport security, input validation and sensitive-data protection checks pass.

7. System Models and Diagrams

7.1 UML use-case diagram 1 - Customer and Teller

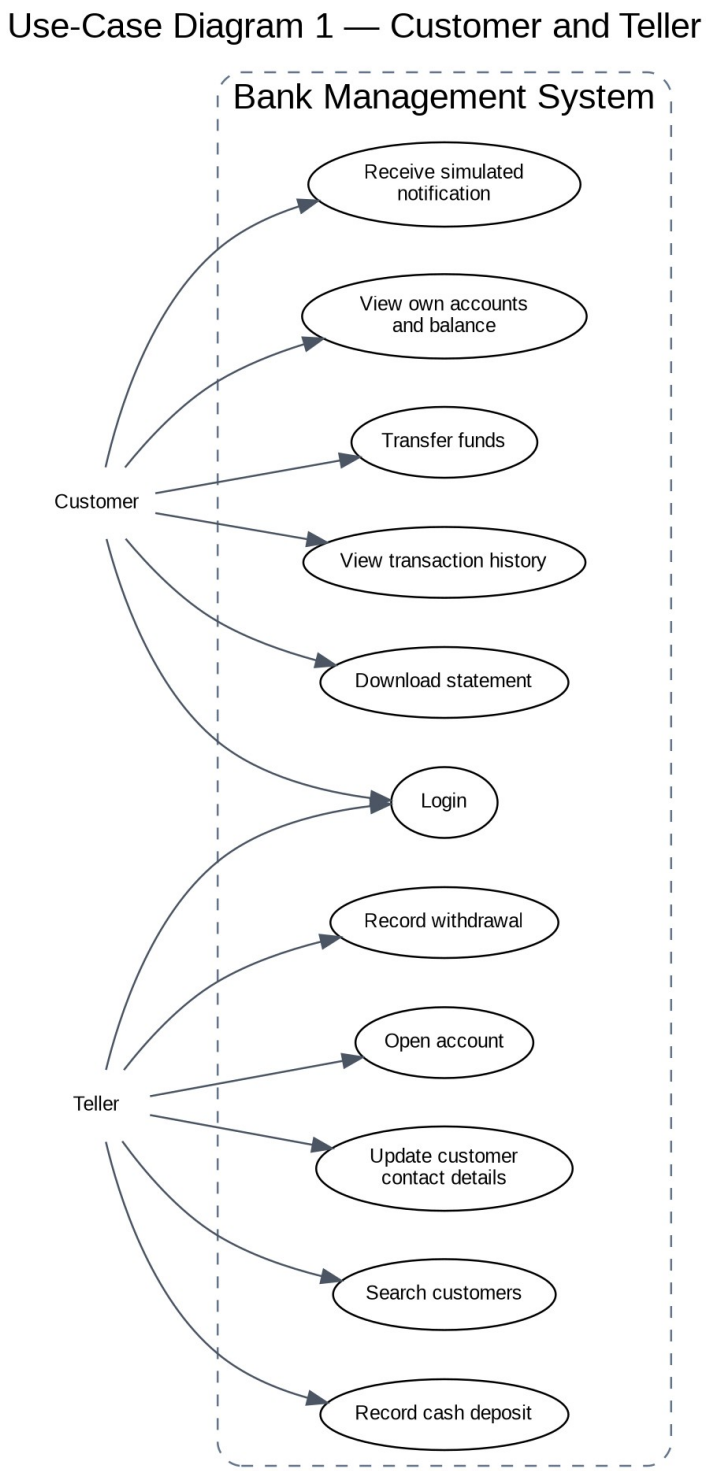


Figure 1. Customer and Teller use-case diagram.

7.2 UML use-case diagram 2 - Admin and system

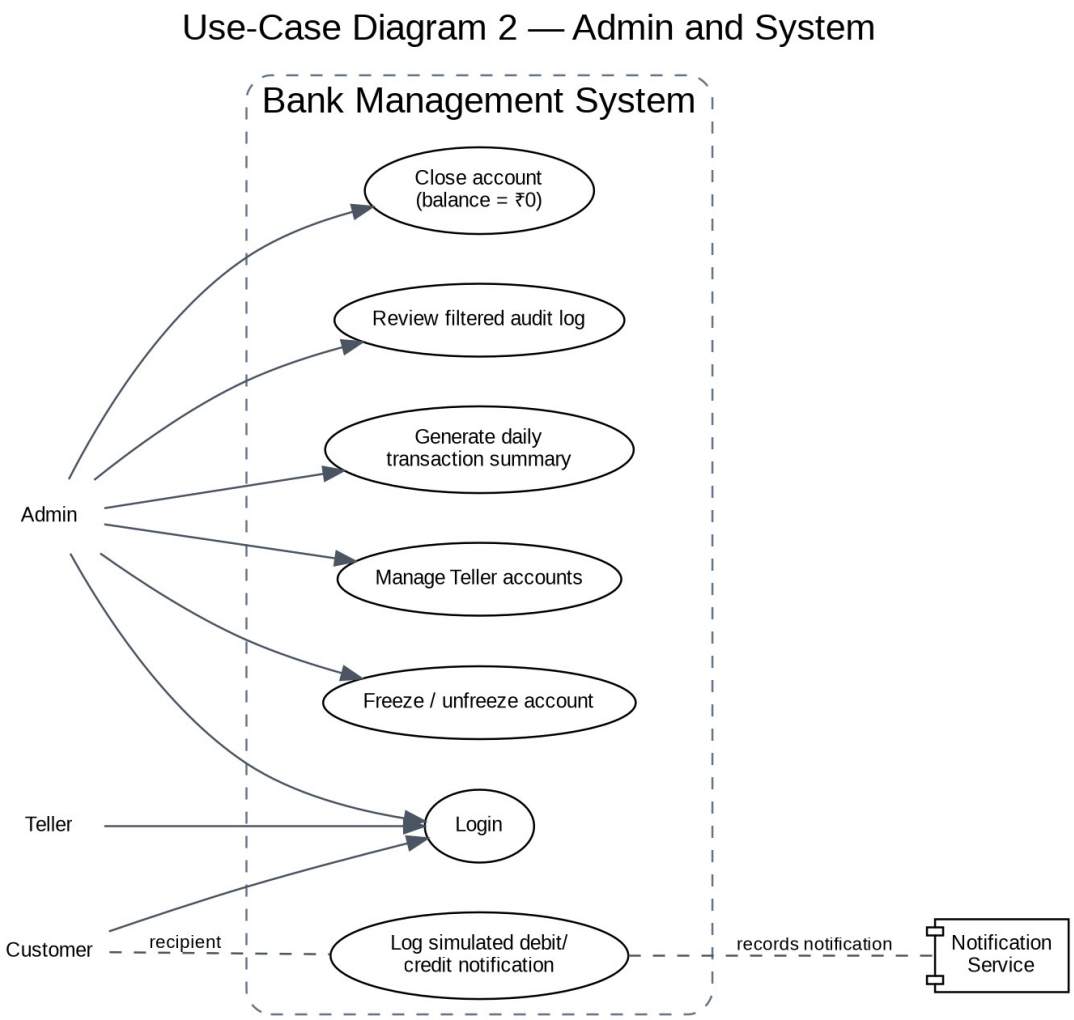


Figure 2. Admin and system use-case diagram. The Notification Service records simulated notifications; no external messaging gateway is in scope.

8. Requirements Traceability Matrix (RTM)

Req ID	Requirement summary	Section / design ref	Module	Test case(s)	Status	Comments
BMS-F-001	Authenticate user / create session	4.1 / DS-AUTH	Auth Service	TC-Auth-01	N	
BMS-F-002	Lock user after 3 failed logins and audit event	4.1 / DS-AUTH, DS-AUD	Auth Service / Audit Service	TC-Auth-02	N	
BMS-F-003	Enforce role-based access	4.1 / DS-AUTH	Auth Service	TC-RBAC-01	N	
BMS-F-004	Change password / force first-login change	4.1 / DS-AUTH	Auth Service	TC-Auth-03	N	
BMS-F-010	Open account, record opening deposit and create first Customer login only if needed	4.2 / DS-ACC, DS-AUTH, DS-TXN, DS-DB	Account Service	TC-Acc-01	N	Account number, minimum deposit, email capture, one-time temporary

Req ID	Requirement summary	Section / design ref	Module	Test case(s)	Status	Comments
						password, no duplicate login, and mandatory first-login password change.
BMS-F-011	Update customer contact details and audit old/new values	4.2 / DS-ACC, DS-AUD	Account Service	TC-Acc-02	N	TC-Acc-02 verifies phone, e-mail and address updates and audit log containing both old and new values for each changed field.
BMS-F-012	Freeze, unfreeze or close account	4.2 / DS-ACC, DS-TXN, DS-AUD	Account Service	TC-Acc-03	N	TC-Acc-03 verifies non-Admin requests are denied; frozen/closed accounts cannot transact; non-zero balance blocks closure; freeze/unfreeze/close actions are audited.
BMS-F-013	Customer views only own account details and balance	4.2 / DS-ACC, DS-AUTH, DS-DB	Account Service	TC-Acc-04	N	TC-Acc-04 verifies own-account view and server-side HTTP 403 for cross-customer account access.
BMS-F-014	Teller searches customers by name, account number or phone	4.2 / DS-ACC, DS-DB	Account Service	TC-Acc-05	N	TC-Acc-05 verifies full/partial name, account-number and phone search; “No results”; only last four account digits shown; each search returns within 2 seconds.
BMS-F-020	Record cash deposit	4.3 / DS-TXN	Transaction Service	TC-Dep-01	N	
BMS-F-021	Record withdrawal within limits	4.3 / DS-TXN	Transaction Service	TC-WD-01, TC-WD-02	N	
BMS-F-022	Transfer funds between BMS accounts	4.3 / DS-TXN, DS-DB	Transaction Service + Data Access Layer	TC-TR-01, TC-TR-02	N	
BMS-F-023	View transaction history / mini-	4.3 / DS-TXN	Transaction Service	TC-Stmt-01	N	

Req ID	Requirement summary	Section / design ref	Module	Test case(s)	Status	Comments
	statement					
BMS-F-024	Download CSV/PDF statement	4.3 / DS-TXN	Transaction Service	TC-Stmt-02	N	
BMS-F-030	Create, deactivate and unlock Teller users	4.4 / DS-ADM	Admin & Reporting Service	TC-Adm-01	N	
BMS-F-031	Admin filters and views audit log	4.4 / DS-AUD	Audit & Notification Service	TC-Aud-01	N	
BMS-F-032	Generate daily transaction summary	4.4 / DS-ADM	Admin & Reporting Service	TC-Rep-01	N	
BMS-F-033	Log simulated notification after every debit/credit	4.4 / DS-AUD	Audit & Notification Service	TC-Not-01	N	
BMS-NF-001	Transaction response time under 50-user load	5 / DS-TXN	Transaction Service	TC-Perf-01	N	
BMS-NF-002	99.5% monthly availability and health endpoint	5 / DS-UI	Web UI / Platform	TC-Ops-01	N	
BMS-NF-003	Atomic financial transactions	5 / DS-TXN, DS-DB	Transaction Service + Data Access Layer + Database	TC-TR-02	N	
BMS-NF-004	First-time-user transfer usability	5 / DS-UI	Web UI / Platform	TC-UX-01	N	At least 9 of 10 first-time users complete a fund transfer within 2 minutes without assistance.
BMS-NF-005	Timestamped, append-only, 5-year audit retention	5 / DS-AUD	Audit & Notification Service	TC-Aud-02	N	
BMS-NF-006	Browser compatibility and 360 px responsive UI	5 / DS-UI	Web UI / Platform	TC-UX-02	N	
BMS-SR-001	TLS 1.2+ for client-server communication	5.1 / DS-SEC	Security Layer	TC-Sec-01	N	
BMS-SR-002	Salted password hashes; never log passwords	5.1 / DS-AUTH	Auth Service	TC-Sec-02	N	
BMS-SR-003	Expire session after 10 minutes idle	5.1 / DS-AUTH	Auth Service	TC-Sec-03	N	
BMS-SR-004	Server-side role authorization every request	5.1 / DS-AUTH	Auth Service	TC-RBAC-01	N	
BMS-SR-005	Validate input; protect against SQL injection and XSS	5.1 / DS-SEC	Security Layer	TC-Sec-04	N	
BMS-SR-006	Audit login, financial and admin actions	5.1 / DS-AUD	Audit & Notification Service	TC-Aud-01	N	
BMS-SR-007	Mask account numbers; encrypt ID-proof numbers	5.1 / DS-SEC, DS-DB	Security Layer + Data Access Layer	TC-Sec-05	N	Storage and encryption are defined in the SAD (DS-SEC, DS-DB).

Project: Bank Management System
Version: 1.0 | Authors: BMS_PES – Vaibhava, Ronit, Vijay, Tarini
Date: 12-10-2026 | Status: Draft